

Designing a National Roadmap for Post-Quantum Cybersecurity

A Strategic Transition Framework for the Federal Republic of Germany

Hendrik Schütz

ITU Course: Quantum Communications and Post-Quantum Cybersecurity: The Next Frontier, Final Policy Analysis Assignment, Theme 1, April 2026

Executive Summary

The emergence of cryptographically relevant quantum computers (CRQCs) poses an existential challenge to all current public-key cryptography, including RSA, ECDSA, and Diffie-Hellman. Credible timelines place CRQCs capable of breaking 2048-bit RSA within the 2030-2035 window. Mosca's Law captures the urgency: for data with long-term secrecy requirements, Germany's combined migration duration and threat timeline already approaches or exceeds the required confidentiality lifespan. Critically, **Harvest Now, Decrypt Later (HNDL)** attacks, in which adversaries collect encrypted data today to decrypt it once CRQC capability is achieved, make this threat operationally active now. Intelligence agencies including BfV and BND have publicly flagged HNDL as an active vector targeting German government communications, KRITIS data, and classified research.

This roadmap proposes a structured, five-phase national transition to post-quantum cryptography (PQC) for Germany spanning 2025-2032, grounded in NIST FIPS 203/204/205, BSI TR-02102, ENISA's EU-level PQC recommendations, and NATO CNSA 2.0. Developed from the perspective of a practitioner holding CompTIA Security+, Pentest+, and CySA+ certifications alongside ITU training in national cybersecurity strategy, it covers cryptographic asset inventory, risk-tiered migration, governance architecture, OT/ICS constraints, workforce development, and binding EU and NATO alignment.

1. Technical and Standards Baseline

All public-sector PQC deployments are restricted to algorithms standardized by NIST or formally adopted by BSI in TR-02102. Two architectural principles are non-negotiable. First, **cryptographic agility**: every system must implement algorithm abstraction layers enabling primitive substitution without architectural overhaul, a direct lesson from the 2022 Castryck and Decru attack that collapsed SIDH/SIKE using classical mathematics alone, shortly before NIST's final round concluded. Second, **hybrid schemes** combining classical algorithms such as X25519 with PQC counterparts such as ML-KEM-768 are mandated during the transition period for backward compatibility and simultaneous defense against both adversary classes.

Standard	Body	Application in Germany
FIPS 203 (ML-KEM/Kyber)	NIST	Primary key encapsulation; mandatory for all federal TLS, VPN, and encrypted storage from Phase 2
FIPS 204 (ML-DSA/Dilithium)	NIST	Primary digital signature; replaces ECDSA in national PKI, code signing, and eGovernment (eIDAS 2.0)
FIPS 205 (SLH-DSA/SPHINCS+)	NIST	Hash-based backup signature; mandated alongside ML-DSA for highest-criticality systems given its independent mathematical basis
BSI TR-02102 (2026 update)	BSI	German cryptographic baseline incorporating FIPS 203/204/205 with implementation guidance and RSA/ECDSA deprecation schedule
ENISA PQC Guidelines 2024	ENISA	EU harmonization baseline preventing digital single market fragmentation
NATO CNSA 2.0	NSA/NATO	Binding requirement for all Bundeswehr and defence-adjacent systems interfacing with NATO classified networks

2. Five-Phase National Transition Roadmap (2025-2032)

Phase	Period	Focus and Key Actions	Lead Entities
1. Inventory	2025-2026	Mandatory Cryptographic Bill of Materials (CBOM) for all federal systems and KRITIS operators. HNDL risk scoring: data with confidentiality horizon beyond 5 years is Priority 1. BSI establishes national PQC registry. Cryptographic agility mandated in all new IT procurement from 2026.	BSI, BMI, Federal Agencies, KRITIS operators
2. Pilots	2026-2027	Hybrid TLS 1.3 (X25519 plus ML-KEM-768) across federal VPN and web infrastructure. ML-DSA code signing for all federal software. BaFin supervisory guidance to systemically relevant financial institutions. BSI TR-02102 updated with FIPS 203/204/205 and RSA/ECDSA deprecation timelines.	BSI, BfV, ITZBund, BaFin
3. KRITIS Migration	2027-2029	National PKI overhaul: D-TRUST and Telesec root CAs transition to PQC-capable chains with dual-algorithm certificates during the overlap period. Sector-differentiated OT/ICS strategy: network-level PQC gateways for legacy constrained systems; hardware refresh aligned to normal replacement cycles. Gematik ePA migrated. Next-generation BOS communications systems procured from 2027 onwards designed PQC-native.	BSI, BBK, Gematik, BNetzA, Energy and Transport operators
4. Broad Rollout	2029-2031	Mittelstand PQC voucher scheme: BMWi co-funds up to 50% of migration costs for SMEs in KRITIS supply chains. All 16 German federal states submit PQC roadmaps via the Federal IT Planning Council. BSI IT-Grundschutz PQC module mandatory for public-sector certification. DFG funds PQC chairs at TU Munich, KIT, and TU Berlin.	BMWi, IT-Planungsrat, State CISOs, Gematik, KBV
5. Audit and Optimization	2031-2032	Independent national PQC audit by Bundestag IT Committee. Cryptographic agility validation across all migrated systems. Residual RSA/ECC deployments formally closed or extended. Full eIDAS 2.0 and NIS2 compliance verified. Permanent BSI quantum threat observatory established.	BSI, Bundestag, ENISA, NATO

3. Governance Architecture

Germany's existing cybersecurity governance, centred on BSI, the National Cyber Security Council, and the IT-Planungsrat, provides the structural foundation, extended by a cross-ministry PQC Steering Committee. A key lesson from Germany's IPv6 rollout and eGovernment Act implementation is that **voluntary frameworks fail to achieve the required adoption pace**. PQC compliance is therefore mandatory for all public-sector entities and KRITIS operators, with an incentivized voluntary track for the broader private sector.

Entity	Mandate and Role in PQC Transition
BSI	Primary technical authority: CBOM registry, TR-02102 updates, sector guidance, audit coordination, quantum threat observatory
BMI	Legislative authority: KRITIS operator obligations under BSIG, inter-ministerial coordination
PQC Steering Committee (proposed)	Cross-ministry body chaired by National Cyber Security Council; quarterly reporting to Bundestag
IT-Planungsrat	Federal-state alignment: roadmap mandates for all German federal states, shared procurement language, interoperability standards
BfV/BND	HNDL threat monitoring, CRQC capability tracking, classified system prioritization
BaFin/BNetzA/Gematik	Sector regulators: binding supervisory guidance for finance, telecoms, and healthcare migration
BMWi	Mittelstand Digital PQC voucher scheme; industrial adoption incentives; R&D co-funding

4. Critical Challenges and Risk Mitigation

4.1 Algorithm Risk

No PQC algorithm is mathematically proven secure against all future attacks. The 2022 Castryck and Decru attack on SIDH/SIKE collapsed a leading NIST candidate using classical mathematics alone, illustrating that even extensively peer-reviewed schemes can fail. Lattice-based schemes (ML-KEM, ML-DSA) rest on the hardness of Module Learning With Errors; hash-based SLH-DSA relies on well-understood collision resistance with an independent mathematical foundation. Mitigations: cryptographic agility as a non-negotiable design requirement; parallel deployment of ML-DSA and SLH-DSA for highest-criticality systems; and a BSI quantum threat observatory with pre-defined triggers for emergency algorithm revision.

4.2 OT/ICS Constraints

PQC algorithms impose substantially larger key and signature sizes: ML-KEM-768 public keys are 1,184 bytes versus 294 bytes for ECDH-256; ML-DSA-65 signatures are 3,293 bytes versus 64 bytes for Ed25519. For constrained embedded systems in power grids, railway signalling, and water treatment, these overheads may exceed memory limits or violate real-time constraints. The roadmap addresses this with network-level PQC gateways for legacy OT endpoints, hardware refresh synchronized with normal asset replacement cycles, and BSI sector-specific feasibility matrices identifying where full migration by 2032 is infeasible, with compensating controls formally documented and residual risk publicly reported.

4.3 Workforce Deficit

PQC expertise is globally scarce, and outsourcing to non-EU vendors introduces sovereignty risks incompatible with national security objectives. Drawing on my own experience as a practitioner, professionals holding credentials such as Security+, CISSP, or CySA+ require targeted PQC domain extension rather than full retraining, since threat modeling, risk assessment, and secure architecture principles remain constant across the cryptographic transition. The roadmap prioritizes BSI Academy PQC upskilling tracks for existing professionals, DFG-funded university chairs for pipeline development, and bilateral knowledge exchange with allied agencies including ENISA and NCSC-UK.

5. International Alignment: EU, NATO, and G7

A German PQC transition executed without international coordination creates exploitable seams at precisely the interfaces adversaries target. Germany must be a *shaper* of international PQC norms, not merely a *taker*. Germany's KRITIS migration obligations are framed as NIS2 implementing measures, with BSI coordinating with ENISA on harmonized PQC guidelines to prevent digital single market fragmentation. The EU Digital Identity Wallet under eIDAS 2.0 should be designed PQC-capable from the outset. Germany's D-Trust and Gematik lead EU PKI working groups to ensure quantum-safe cross-border certificate recognition is in place at launch. For NATO, all systems interfacing with classified networks must meet CNSA 2.0 requirements covering ML-KEM, ML-DSA, and XMSS/LMS, with Bundeswehr migration explicitly synchronized with the alliance timeline and all deviations requiring SACEUR-level derogation. At G7 level, Germany champions a quantum cryptography coordination process modelled on the 2023 Hiroshima AI process to align allied transition timelines and prevent adversaries from exploiting asymmetric migration progress. Finally, BSI and German industry actively shape hybrid TLS, SSH, and IKEv2 standards in IETF PQC working groups and ISO/IEC SC27 so that EU requirements are embedded in global norms from the drafting stage.

Conclusion

Mosca's Law is unambiguous: the mathematics of Germany's migration timeline demand action now. Three imperatives stand above all others: begin inventory immediately, because HNDL attacks are active today; mandate cryptographic agility without exception, because algorithm assumptions will evolve; and lead internationally, because isolated transitions create seams adversaries exploit. Germany's BSI authority, engineering culture, and EU leadership position it to serve as the reference model for allied nations. The standards are finalized. The roadmap is clear. What remains is the will to act.

References

- [1] NIST (2024). FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.FIPS.203>
- [2] NIST (2024). FIPS 204: Module-Lattice-Based Digital Signature Standard (ML-DSA). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.FIPS.204>
- [3] NIST (2024). FIPS 205: Stateless Hash-Based Digital Signature Standard (SLH-DSA). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.FIPS.205>
- [4] BSI (2023). Technische Richtlinie TR-02102-1: Kryptographische Verfahren, Empfehlungen und Schlüssellängen. Bundesamt für Sicherheit in der Informationstechnik. Version 2023-01.
- [5] ENISA (2024). Post-Quantum Cryptography: Current State and Quantum Mitigation. European Union Agency for Cybersecurity, Heraklion.
- [6] NSA (2022). Commercial National Security Algorithm Suite 2.0 (CNSA 2.0). National Security Agency, Fort Meade, MD.
- [7] NIST (2023). NIST IR 8547: Transition to Post-Quantum Cryptography Standards. National Institute of Standards and Technology.
- [8] CISA / NSA / NIST (2023). Quantum-Readiness: Migration to Post-Quantum Cryptography. Joint Cybersecurity Advisory.
- [9] Castryck, W. and Decru, T. (2022). An Efficient Key Recovery Attack on SIDH. IACR ePrint Archive 2022/975.
- [10] Mosca, M. (2018). Cybersecurity in an Era with Quantum Computers: Will We Be Ready? IEEE Security and Privacy, 16(5), 38-41.
- [11] EU (2022). Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS2). Official Journal of the European Union.
- [12] NATO Science and Technology Organization (2023). Quantum Technologies for Defence: Technology Trend Assessment. STO-TR-SET-299.
- [13] Global Risk Institute (2023). Quantum Threat Timeline Report. Toronto: Global Risk Institute.
- [14] IETF (2023). draft-ietf-tls-hybrid-design: Hybrid key exchange in TLS 1.3. Internet Engineering Task Force.
- [15] BSI (2022). Lagebericht zur IT-Sicherheit in Deutschland 2022. Bundesamt für Sicherheit in der Informationstechnik.